



المرجع الخليجي الشامل في الأمن السيبراني

الأسس والضوابط والعمليات والتنظيم

علي العنزي

3li.info

نسخة مجانية

اقرأ الفصل الأول

هذه النسخة تضم الافتتاحية والمقدمة ودليل القراءة والفصل الأول كاملاً،
والكتاب بفصوله التسعة عشر متاح الآن على أمازون.

اشترِ الكتاب من أمازون

gulfcyber.3li.info



المرجع الخليجي الشامل في الأمن السيبراني

الأسس والضوابط والعمليات والتنظيم

علي العنزي

2026

المرجع الخليجي الشامل في الأمن السيبراني

علي العنزي

الطبعة الأولى 2026

جميع الحقوق محفوظة للمؤلف، فلا يجوز نسخ أي جزء من هذا الكتاب أو تخزينه أو نقله بأي وسيلة دون إذن كتابي مسبق منه، ويستثنى من ذلك الاقتباس القصير في المراجعات والدراسات مع الإشارة إلى المصدر.

الرقم الدولي المعياري للكتاب ISBN 9798178685440، والنسخة

الورقية منشورة نشرًا مستقلاً Independently published.

تصميم الغلاف والأشكال من عمل المؤلف.

موقع الكتاب والتدريبات المرافقة له على gulfcyber.3li.info

للتواصل مع المؤلف: info@3li.info



المحتويات

xxi	افتتاحية
xxiii	المقدمة
xxv	كيف تقرأ هذا الكتاب
xxvii	شكر وتقدير

1 الباب الأول: الأسس

3	مدخل إلى أمن المعلومات	1
4	1.1 ما المعلومات ولماذا نحميها	
6	1.2 الخصائص الثلاث: السرية والسلامة والتوافر . .	
9	1.3 أمن المعلومات والأمن السيبراني وحماية البيانات .	
10	1.4 المفردات الأربع: الأصل والتهديد والثغرة والخطر	
11	1.5 مبادئ لا تتغير	
13	1.6 أنواع الضوابط	
14	1.7 لماذا تُخترق المؤسسات مع كل هذا	
15	1.8 الأمن عملية مستمرة لا منتج يُشترى	

21	التحديات والمهاجمون	2
22	2.1 من يهاجمنا ولماذا	
23	2.2 تشريح الهجوم	
24	2.3 الهندسة الاجتماعية	
26	2.4 البرمجيات الخبيثة	
28	2.5 هجمات الشبكات والأنظمة	
29	2.6 التهديد الداخلي	
30	2.7 مشهد التهديدات في الخليج	
31	2.8 كيف يفكر المدافع	
37	إدارة المخاطر	3
38	3.1 لماذا نبدأ من الخطر لا من التقنية	
39	3.2 خطوات إدارة المخاطر	
40	3.3 جرد الأصول وتصنيفها	
41	3.4 تحديد التهديدات والثغرات	
42	3.5 تحليل المخاطر بين النوعي والكمي	
43	3.6 معالجة المخاطر	
44	3.7 شبيهة المخاطر وتحملها	
45	3.8 سجل المخاطر الحي	
46	3.9 مخاطر الأطراف الثالثة وسلسلة التوريد	
47	3.10 المخاطر في سياقنا الخليجي	
53	الحوكمة والسياسات والأطر والامثال	4
54	4.1 ما الحوكمة ولماذا تفشل البرامج بدونها	
55	4.2 أين يقع أمن المعلومات في الهيكل	
56	4.3 هرم الوثائق	
57	4.4 الأطر والمعايير الدولية	
59	4.5 المشهد التنظيمي في الخليج	

63	الامثال ليس أمناً	4.6
64	قياس البرنامج ورفع تقاريره	4.7
65	التأكيد والتدقيق	4.8

71 الباب الثاني: الضوابط التقنية

73	5 التشفير
74	5.1 ما يفعله التشفير وما لا يفعله
75	5.2 التشفير المتماثل
76	5.3 التشفير غير المتماثل
76	5.4 دوال التجزئة ورموز المصادقة
77	5.5 التوقيع الرقمي
78	5.6 البنية التحتية للمفاتيح العامة
79	5.7 تأمين النقل بروتوكول TLS
80	5.8 كيف تختار الخوارزمية وطول المفتاح
81	5.9 التشفير أثناء الاستخدام والحوسبة السرية
82	5.10 أخطاء التطبيق التي تبطل أقوى الخوارزميات ..
82	5.11 إدارة المفاتيح ودورة حياتها
83	5.12 التشفير في واقعنا
84	5.13 ما بعد الحوسبة الكمية

91 6 الهوية والمصادقة وإدارة الصلاحيات

92	6.1 المصطلحات الأربعة
93	6.2 عوامل المصادقة
94	6.3 كلمات المرور ما زالت معنا
95	6.4 الدخول الموحد واتحاد الهويات
96	6.5 نماذج التحكم في الوصول

97	6.6	إدارة الحسابات ذات الصلاحيات الحساسة . . .
97	6.7	دورة حياة الهوية
98	6.8	الهويات غير البشرية
98	6.9	حوكمة الهوية وإدارتها
99	6.10	هوية العملاء
100	6.11	الدليل النشط وما حوله
101	6.12	انعدام الثقة
101	6.13	الهوية الرقمية الوطنية في الخليج

7 أمن الشبكات 109

110	7.1	الشبكة من منظور المدافع
111	7.2	تجزئة الشبكة والمناطق
112	7.3	جدران الحماية بأجياها
113	7.4	كشف التسلل ومنعه
113	7.5	الوصول عن بعد والشبكات الخاصة الافتراضية
114	7.6	أمن نظام أسماء النطاقات
115	7.7	الشبكات اللاسلكية
116	7.8	التحكم في الوصول إلى الشبكة والبروتوكولات القديمة
116	7.9	الحماية من حجب الخدمة
117	7.10	مراقبة حركة الشبكة
118	7.11	الفروع والعمل من أي مكان
118	7.12	الشبكة داخل مركز البيانات
119	7.13	مثال تطبيقي: تجزئة شبكة مؤسسة متوسطة
120	7.14	الشبكة في المؤسسة الخليجية

8 أمن الأنظمة ونقاط النهاية 127

128	8.1	التهية الآمنة والتحصين
130	8.2	إدارة الثغرات والتحديثات

8.3	من مكافحة الفيروسات إلى كشف نقاط النهاية والاستجابة	132
8.4	الصلاحيات على الجهاز	133
8.5	الأجهزة المحمولة	133
8.6	التشفير على الأجهزة والوسائط	134
8.7	التسجيل على مستوى النظام	134
8.8	الحوادم والبيئات الافتراضية	135
8.9	الأنظمة القديمة التي لا تموت	136
8.10	نقاط النهاية في المؤسسة الخليجية	136

9 أمن التطبيقات والتطوير الآمن 143

9.1	أشهر ثغرات التطبيقات	144
9.2	دورة التطوير الآمنة	146
9.3	نمذجة التهديدات للتطبيقات	147
9.4	الاختبارات الأمنية للتطبيقات	148
9.5	أمن واجهات البرمجة	149
9.6	أمن سلسلة توريد البرمجيات	150
9.7	الأمن في خط التسليم المستمر	150
9.8	الحماية في زمن التشغيل	151
9.9	التطبيقات في المؤسسة الخليجية	151

10 أمن الحوسبة السحابية 159

10.1	نماذج الخدمة والنشر	160
10.2	المسؤولية المشتركة	161
10.3	الهوية في السحابة	162
10.4	الهيئة الخاطئة وإدارة الوضع الأمني	163
10.5	الحاويات والخدمات المصغرة	164
10.6	حماية البيانات في السحابة	164

165	10.7	الشبكات السحابية
166	10.8	المراقبة والتسجيل في السحابة
166	10.9	أمن البرمجيات كخدمة
167	10.10	الحوكمة والامتثال والتوطين في الخليج
167	10.11	استراتيجية الخروج ومخاطر التركيز

11 أمن البيانات والخصوصية 175

176	11.1	التصنيف أساس كل شيء
178	11.2	دورة حياة البيانات وضوابطها
179	11.3	منع تسريب البيانات
179	11.4	التشفير والتعميم والاستبدال بالرموز
180	11.5	النسخ الاحتياطي والإتلاف الآمن
181	11.6	مبادئ الخصوصية
182	11.7	تقييم الأثر على الخصوصية
183	11.8	خروقات البيانات والإبلاغ عنها
183	11.9	البيانات في المؤسسة الخليجية

12 أمن الأنظمة الصناعية وإنترنت الأشياء 191

192	12.1	عالم مختلف بأولويات معكوسة
193	12.2	نموذج ييردو والمناطق والقنوات
194	12.3	البروتوكولات الصناعية
195	12.4	التحديات على قطاعات المنطقة
196	12.5	الضوابط الأساسية
197	12.6	دراسة حالة: محطة تحلية افتراضية
197	12.7	المراقبة دون تعطيل
198	12.8	أمن إنترنت الأشياء
199	12.9	البنية التحتية الحيوية في الخليج
199	12.10	الاستجابة للحوادث في البيئات الصناعية

13 المعمارية الأمنية 207

13.1	ما المعمارية الأمنية ولماذا	208
13.2	الأطر المعمارية	209
13.3	المبادئ المعمارية	210
13.4	الأنماط المعمارية الآمنة	211
13.5	معمارية انعدام الثقة	212
13.6	المعمارية السحابية والبيئة التأسيسية	213
13.7	مراجعة المعمارية في المؤسسة	214
13.8	قياس نضج المعمارية	215
13.9	المعمارية الأمنية في المؤسسة الخليجية	216
13.10	دراسة حالة: بنك يطلق تطبيق هاتف	216

الباب الثالث: العمليات والصمود 223

14 مراقبة الأمن والعمليات الأمنية 225

14.1	الرؤية قبل الأدوات	226
14.2	مركز العمليات الأمنية	227
14.3	السجلات	227
14.4	إدارة المعلومات والأحداث الأمنية	228
14.5	هندسة الكشف وحالات الاستخدام	229
14.6	استخبارات التهديدات	229
14.7	صيد التهديدات	230
14.8	الأتمتة والتنسيق	231
14.9	قياس أداء المركز	231
14.10	الاستعانة بمزود خارجي	231
14.11	مركز العمليات في المؤسسة الخليجية	232
14.12	دراسة حالة: التنبيه الذي لم يُقرأ	232

15 الاستجابة للحوادث والتحقيق الرقمي 239

15.1	الحدث والحادثة والحرق	240
15.2	دورة الاستجابة	241
15.3	الاستعداد	242
15.4	الساعة الأولى	242
15.5	الكشف والتحليل	243
15.6	الاحتواء والاستئصال والتعافي	243
15.7	التواصل والإبلاغ التنظيمي	244
15.8	التحقيق الرقمي	245
15.9	الدروس المستفادة	246
15.10	التمارين	246
15.11	دراسة حالة: برمجية فدية في مؤسسة متوسطة	247

16 استمرارية الأعمال والتعافي من الكوارث 253

16.1	المرونة التشغيلية بوصفها الهدف	254
16.2	تحليل الأثر على الأعمال	255
16.3	استراتيجيات التعافي	257
16.4	السحابة والمرونة	257
16.5	النسخ الاحتياطي في مواجهة الفدية	258
16.6	الخطط	258
16.7	التمارين والاختبارات	259
16.8	اضطرابات ليست سيبرانية	259
16.9	قائمة تحقق للاختبار السنوي	260
16.10	الأطراف الثالثة والتركز	260
16.11	المرونة التشغيلية في الأطر الخليجية	261
16.12	دراسة حالة: فقدان مركز بيانات	261

17 العنصر البشري والتوعية الأمنية 267

17.1	لماذا يفشل التدريب التقليدي	268
17.2	من التوعية إلى السلوك إلى الثقافة	268
17.3	بناء برنامج التوعية	269
17.4	محاكاة التصيد	270
17.5	الرسالة التي تصل	271
17.6	القيادة والقُدوة	271
17.7	أمن الموظفين من التعيين إلى المغادرة	271
17.8	الهندسة الاجتماعية في البيئة الخليجية	272
17.9	التوعية للعملاء والجمهور	273
17.10	التدريب بالمحاكاة والألعاب	273
17.11	الأمن في حياة الموظف الشخصية	274
17.12	دراسة حالة: حوالة مزورة	274
17.13	قياس البرنامج	275

281 الباب الرابع: آفاق

18	الذكاء الاصطناعي وأمن المعلومات	283
18.1	الذكاء الاصطناعي في يد المهاجم	284
18.2	الهجمات على نماذج اللغة الكبيرة والأنظمة المبنية عليها	285
18.3	حوكمة استخدام الذكاء الاصطناعي في المؤسسة	286
18.4	النماذج المدربة داخلياً	287
18.5	أسئلة قبل اعتماد أي أداة	287
18.6	الذكاء الاصطناعي في الدفاع	288
18.7	الأطر الناشئة	288
18.8	الاحتيال على الأفراد والعائلات	289
18.9	دراسة حالة: المساعد الذي يقرأ البريد	290

297	المسيرة المهنية في أمن المعلومات
298	19.1 خريطة التخصصات
299	19.2 المهارات التي تسبق كل شيء
300	19.3 الشهادات بقيمتها الحقيقية
300	19.4 بناء الخبرة قبل الوظيفة وبعدها
301	19.5 مسارات نموذجية
302	19.6 السيرة الذاتية والمقابلة
302	19.7 التعلم الذي لا يتوقف
302	19.8 سوق العمل الخليجي
303	19.9 دور الجامعات والجهات الحكومية
304	19.10 أخلاقيات المهنة
304	19.11 الخطة الشخصية

313 الملاحق

313	قائمة تحقق للمؤسسة الصغيرة والمتوسطة
313	الهوية والحسابات
314	الأجهزة والأنظمة
314	الشبكة والوصول
314	البيانات والنسخ الاحتياطي
315	الأفراد
315	الاستعداد والامثال

317	قائمة تحقق للجهات الحكومية والمؤسسات الكبرى
317	الحكومة والقيادة، الفصلان الثالث والرابع
318	المخاطر والامثال والتدقيق، الفصلان الثالث والرابع
319	الأصول والهوية والصلاحيات، الفصلان الثالث والسادس
320	الأنظمة ونقاط النهاية، الفصلان الثامن والثاني عشر

321	الشبكات والتطبيقات، الفصول السابع والتاسع والثالث عشر
322	البيانات والتشفير، الفصلان الخامس والحادي عشر . . .
	المراقبة والاستجابة، الفصول الرابع عشر والخامس عشر
322	والثامن عشر
323	الاستمرارية والصمود، الفصل السادس عشر
	الأطراف الخارجية والحوسبة السحابية، الفصلان الثالث
324	والعاشر
324	الأفراد والثقافة، الفصل السابع عشر
325	عشرة أسئلة يطرحها مجلس الإدارة

327 مسرد المصطلحات

353 المراجع والمصادر

353	الأطر والمعايير الدولية
354	الأطر والقوانين الخليجية
356	أبحاث المؤلف
357	الأدلة الفنية والتقارير

359 عن المؤلف



قائمة الأشكال

1.1	ثالث السرية والسلامة والتوافر	6
2.1	مراحل سلسلة القتل السيبرانية السبع	23
3.1	دورة إدارة المخاطر	39
4.1	هرم الوثائق من السياسات إلى الإرشادات	56
5.1	سلسلة الثقة في الشهادات الرقمية	78
6.1	العمليات الأربع لإدارة الهوية والوصول	92
7.1	مناطق الشبكة من الأقل ثقة إلى الأعلى حساسية	111
8.1	دورة إدارة الثغرات	130
9.1	الأمن في كل مرحلة من دورة التطوير	146
10.1	توزيع المسؤولية بين المزود والعميل	161
11.1	دورة حياة البيانات	178
12.1	مستويات نموذج بيردو والمنطقة المحايدة	193

13.1	طبقات المعمارية الأمنية من الأعمال إلى التشغيل	210
13.2	معمارية مرجعية لمؤسسة مالية بمناطقها ومكوناتها	212
13.3	أركان معمارية انعدام الثقة ونقاط القرار والإنفاذ	213
13.4	البيئة التأسيسية السحابية	214
13.5	مراحل مراجعة المعمارية من الاستقبال إلى التحقق	215
14.1	مسار المراقبة من المصدر إلى الاستجابة	226
15.1	دورة الاستجابة للحوادث	241
16.1	دورة بناء المرونة التشغيلية	255
17.1	من التوعية إلى الثقافة	269
18.1	ما يدخل إلى النموذج وما يخرج منه	286
19.1	عائلات التخصص في أمن المعلومات	299



قائمة الجداول

9	الخصائص الثلاث وما يحفظها	1.1
14	وظائف الضوابط الخمس	1.2
40	دورة إدارة المخاطر	3.1
45	الحقول الأساسية في سجل المخاطر	3.2
59	أشهر الأطر والمعايير وما يناسب كلاً منها	4.1
80	الخيارات التفسيرية المعتمدة لأشيع الحاجات	5.1
94	عوامل المصادقة الشائعة ومقاومتها للتصيد	6.1
119	تقسيم نموذجي لشبكة مؤسسة متوسطة	7.1
145	أشهر فئات ثغرات التطبيقات وضوابطها	9.1
162	توزيع المسؤولية بحسب نموذج الخدمة	10.1
177	مثال لمخطط تصنيف من أربعة مستويات	11.1
256	مثال على مخرجات تحليل الأثر على الأعمال	16.1



افتتاحية

كان الغيص في خليجنا ينزل إلى القاع وحياته معلقة بجبل يمسكه السيب¹ فوق السطح، فإذا شد الغيص الحبل رُفِع، وإذا أُرْخِيَ له غطس واثقاً بمن يشد له الحبل ويرخيه، وهكذا كانت حياتنا في بلاد الخليج العربي كلها معلقة بجبال كهذه، بثقة بين من يشد ومن يرخي، وبما توارثته الأجيال من ثقافتنا البحرية والبرية.

واليوم تتدلى حياتنا من جبال أخرى لا تُرى، أسلاك في قاع البحر وموجات في الهواء وشفرة في أجهزة لا تعرف الولاء، تمر عليها روايتنا وسجلتنا الصحية وهوياتنا وأسرار شركائنا، ويدار بها الماء الذي نشربه والكهرباء التي تبرد بيوتنا والمال الذي نتعامل به، وصار الذي يمسك هذه الجبال ويحرسها هو من نسميه اليوم المختص في أمن المعلومات، وما هو بأقل ممن كان يشد الحبل ويرخيه ثقةً ولا مسؤولية.

كُتِبَ هذا الكتاب لهؤلاء ولمن يريد أن يكون منهم، وكُتِبَ من داخل الميدان لا من بعيد، من غرف العمليات والمراجعات والحوادث والاجتماعات مع الجهات المنظمة، وكُتِبَ جواباً عن سؤال سمعته سنوات

¹ الغيص هو الغواص الذي ينزل إلى قاع البحر ليجمع المحار في موسم الغوص على اللؤلؤ، والسيب هو البحار الذي يمسك حبله فوق سطح الماء ويسحبه إلى الأعلى حين يشد الحبل

من الطالب والمهندس والمدير جميعاً عن مرجع عربي يجمع المجال كله بلغتنا وأطرنا وأمثلتنا، فلم يكن موجوداً فكان لا بد أن يكتب.

ولم أرد كتاباً يترجم ما كُتب في بلاد أخرى ثم يلحق به فصلاً عن الخليج، بل كتاباً يبدأ من هنا، تُذكر فيه أطر مصارفنا المركزية وهيئاتنا الوطنية وقوانين بياناتنا في موضعها من كل فصل، وتُروى فيه حوادث منطقتنا وأخطاء مؤسساتنا وما ينجح فيها حقاً، وتجدر فيه الجامعات والجهات الحكومية مادة تبني عليها، وتُنشر تدريباته وأشكاله وأدواته مفتوحة ليبنى عليها غيري.

ولا يدعي الكتاب أنه الكلمة الأخيرة في مجال يتبدل كل عام، بل هو كلمة أولى أردتها متينة بما يكفي ليبنى عليها، فإن وجدت فيه ما ينفع فأنشره، وإن وجدت فيه خطأً فراسلني، وإن علّمته غيرك فقد أمسكت الحبل لمن بعدك.

علي العنزي، الكويت، 2026.



المقدمة

لم أجد في بداية طريقي المرجع العربي الذي كنت أتمنى أن أقرأه، فالمراجع الأجنبية غزيرة لكنها تخاطب واقعاً غير واقعنا، أنظمة لا نخضع لها وأمثلة لا نعيشها ومصطلحاً لا يعرفه زملاؤنا، والمحتوى العربي متناثر بين ترجمات حرفية ومقالات متفرقة لا يجمعها خيط واحد، فكان على من يتعلم المجال في منطقتنا أن يجمعه بنفسه من عشرات المصادر، وهذا الكتاب محاولة لأن يجده من يأتي بعدي مجموعاً.

يخاطب الكتاب ثلاث فئات من القراء، فهو مدخل منظم لطالب الجامعة والمبتدئ الذي يريد أن يفهم المجال من جذوره، ومرجع عملي للمهندس والمحلل الذي يعمل في الميدان ويحتاج إلى تثبيت المفاهيم وربطها بعضها ببعض، وخريطة واضحة للمدير والقيادي والمسؤول الحكومي الذي يتخذ قرارات تمس أمن مؤسسته دون أن يكون متخصصاً في التفاصيل التقنية، وقد كُتب ليكون مرجعاً تعتمد عليه الجامعات في مقرراتها والجهات الحكومية في برامج التأهيل، ويشرح دليل القراءة في الصفحات التالية كيف يستفيد منه كل قارئ بحسب حاجته.

قسمت الكتاب إلى أربعة أبواب، فيضع الباب الأول الأسس من مفاهيم وتهديدات ومخاطر وحكمة، ويتناول الباب الثاني الضوابط التقنية من التشفير إلى الأنظمة الصناعية ويختتمها بفصل المعمارية الأمنية الذي يجمعها في تصميم واحد، ويعالج الباب الثالث العمليات والصمود من المراقبة

إلى الاستجابة والتعافي والعنصر البشري، ويطل الباب الرابع على الآفاق في الذكاء الاصطناعي والمسيرة المهنية، وتختتم الملاحق الكتاب بقائمتي تحقق، إحداهما للمؤسسة الصغيرة والمتوسطة والأخرى للجهات الحكومية والمؤسسات الكبرى، ومسرّد شامل ومراجع.

وفي الختام فإن هذا الكتاب جهد بشري قابل للخطأ والتحسين، فإن وجدت فيه خطأ أو كان لديك اقتراح فراسلني على info@3li.info وسأكون ممتناً لك، وأسأل الله أن ينفع به كل من قرأه.



كيف تقرأ هذا الكتاب

يختلف القراء فيما يحتاجون إليه من هذا الكتاب، ولذلك رُسمت أربعة مسارات للقراءة، فالطالب والمبتدئ يقرآن الأبواب بترتيبها لأن كل فصل يبني على ما قبله ويحيل إليه، والممارس يبدأ من الفصل الذي يحتاج إليه مباشرة ويرجع إلى الباب الأول حين يصادف مفهوماً يحتاج إلى تثبيت، والقيادي والمسؤول الحكومي يقرآن الباب الأول كاملاً ثم الفصل الثالث عشر عن المعمارية والباب الثالث عن العمليات والصمود لأنها الفصول التي تمس قراراتهما، والمدرّب والأستاذ الجامعي يبنيان المقرر على أهداف التعلم في أول كل فصل والتمارين في آخره ويجدان التدريبات والقوالب والأشكال في المستودع المرافق.

وتتبع فصول الكتاب بنية واحدة، فيبدأ كل فصل بصندوق أهداف التعلم ثم مقدمة تربط الموضوع بالواقع، ثم الأقسام وفيها شكل توضيحي واحد على الأقل وأمثلة ودراسة حالة في كثير منها، ثم أخطاء شائعة تتكرر في مؤسسات المنطقة، ثم قائمة تحقق يقيس بها القارئ مؤسسته، ثم خلاصة الفصل، ثم جدول المصطلحات بالعربية والإنجليزية، ثم خريطة إلى الأطر الدولية والخليجية التي يقابلها الفصل، ثم أسئلة للمراجعة، ثم تمارين تطبيقية، ثم مصادر للتعمق.

وأتبعت في الكتاب قواعد ثابتة، فالمصطلح الإنجليزي يُذكر بين قوسين عند أول ورود له في كل فصل ويُجمع المسرد في آخر الكتاب، والأعداد بالأرقام الغربية، وأسماء الأطر والمعايير بأسمائها الرسمية مع رموزها الدولية، والأمثلة لا تذكر مؤسسات بعينها إلا ما صار حدثاً عاماً موثقاً، وحين يُذكر إطار خليجي فالمقصود إصداره النافذ وقت الكتابة، ويحسن الرجوع إلى الجهة المصدرة لمعرفة أحدث إصدار، وتجد التدريبات والقوالب والأشكال والأدوات في موقع الكتاب gulfcyber.3li.info وفي مستودعه المفتوح، وفي الموقع نفسه قناة لإبلاغ الأخطاء واقتراح التحسينات.



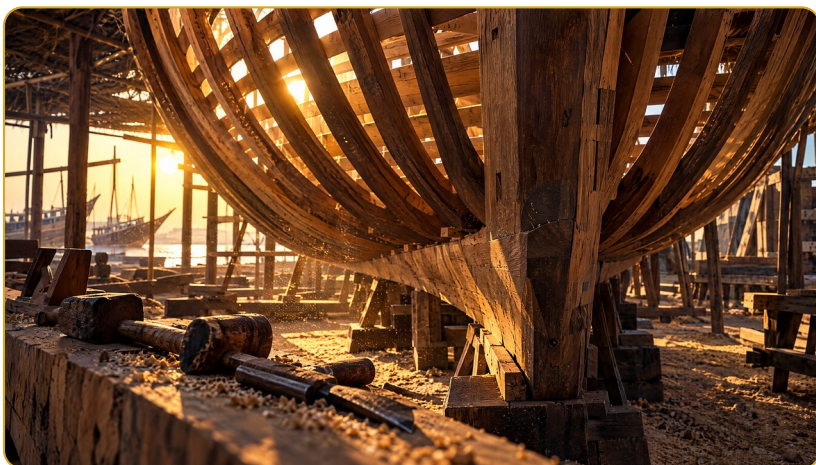
شكر وتقدير

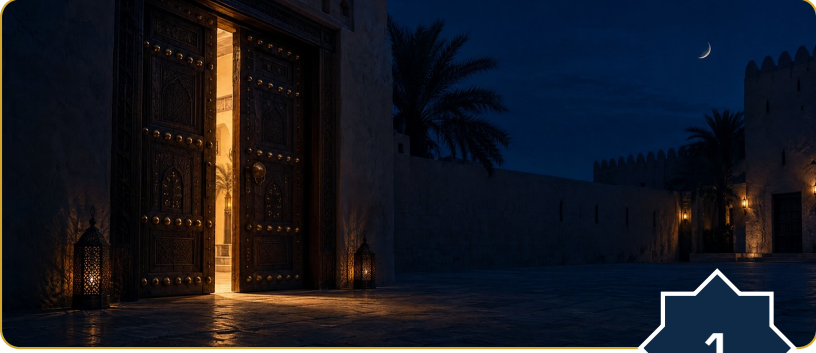
لم يكتب هذا الكتاب في عزلة، فكل فكرة فيه مرت بنقاش مع زميل أو اختبار في ميدان أو سؤال من طالب، فالشكر لزملائي في القطاع المالي الخليجي الذين تعلمت منهم أن الأمن قرار قبل أن يكون أداة، ولأعضاء لجان الأمن السيبراني القطاعية الذين يثبتون كل أسبوع أن المؤسسات تحمي بعضها بعضاً حين تتشارك، وللجهات المنظمة في دول المجلس التي حولت الأمن من توصية إلى إطار، ولطلائي ومتدربي الذين كانت أسئلتهم أصدق مراجعة لكل فصل، وللمجتمع المصادر المفتوحة الذي بُنيت بأدواته تدريبات هذا الكتاب وأشكاله وغلافه، ولأسرتي التي تحملت ساعات الكتابة الطويلة وكانت أول من قرأ، فما فيه من صواب فبفضلهم جميعاً وما فيه من خطأ فعليّ وحدي.



الباب الأول

الأسس





الفصل الأول

مدخل إلى أمن المعلومات

♦ في هذا الفصل

10	المفردات الأربع: الأصل والتهديد والثغرة والخطر	1.4	4	ما المعلومات ولماذا نحميها	1.1
11	مبادئ لا تتغير	1.5	6	الخصائص الثلاث: السرية والسلامة والتوافر	1.2
13	أنواع الضوابط	1.6		أمن المعلومات والأمن السبراني	1.3
14	لماذا تُخترق المؤسسات مع كل هذا	1.7	9	وحماية البيانات	
15	الأمن عملية مستمرة لا منتج يُشتري	1.8			

🎯 أهداف التعلم

بعد دراسة هذا الفصل ستكون قادراً على:

- تعريف المعلومات وتمييزها عن البيانات والمعرفة وبيان سبب حمايتها
- شرح خصائص السرية والسلامة والتوافر والخصائص المكملة لها بأمثلة
- التمييز بين أمن المعلومات والأمن السبراني وحماية البيانات
- استخدام مفردات الأصل والتهديد والثغرة والخطر والضوابط استخداماً صحيحاً
- تصنيف الضوابط بحسب طبيعتها ووظيفتها وشرح المبادئ الثابتة للحماية

في صباح يوم عمل عادي يصل مدير العمليات في شركة متوسطة إلى مكتبه فيجد شاشات الموظفين كلها تعرض رسالة واحدة تخبره بأن ملفات

الشركة سُقِرَتْ وأن استعادتها تتطلب دفع مبلغ بعملة رقمية في غضون ثلاثة أيام، فتتوقف الفواتير والرواتب والعقود دفعة واحدة، ويكتشف الجميع في تلك اللحظة أن الشركة لم تكن تبيع منتجات فحسب بل كانت تقوم على معلومات لم يفكر أحد في حمايتها جدياً.

تتكرر هذه القصة كل يوم بأشكال مختلفة في المستشفيات والجامعات والجهات الحكومية والبنوك والمتاجر الصغيرة، وما يجمع بين ضحاياها ليس ضعف التقنية وحده بل غياب الفهم المنظم لما ينبغي حمايته ومن يهدده وكيف تُبنى الحماية، ولذلك يبدأ هذا الكتاب من الأساس، أي من تعريف المعلومات وخصائصها التي نحميها والمفردات التي يتحدث بها المختصون والمبادئ التي لا تتغير مهما تغيرت التقنية.

1.1 ما المعلومات ولماذا نحميها

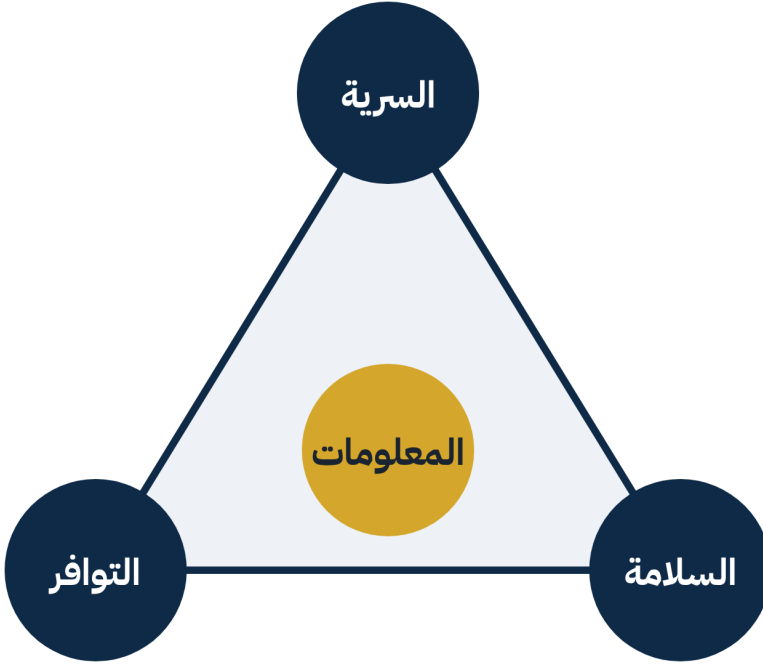
تبدأ الحكاية بالبيانات (Data) وهي حقائق خام لا معنى لها في ذاتها كرقم هاتف منفرد أو تاريخ أو مبلغ، فإذا رُبطت هذه البيانات بما حولها صارت معلومات (Information) كأن نعرف أن هذا الرقم يخص عميلاً بعينه وأن ذلك المبلغ هو رصيده في تاريخ محدد، وإذا تراكمت المعلومات وفُسرَت صارت معرفة (Knowledge) تُبنى عليها القرارات، ونحن نحكي المعلومات لأن لها قيمة، فقيمتها قد تكون مالية كبيانات البطاقات المصرفية، أو قانونية كالعقود والسجلات الطبية، أو تنافسية تخطط المنتجات وأسعار العطاءات، أو إنسانية كصور العائلة وأسرار المرضى، وقد تكون قيمتها في مجرد توافرها في اللحظة المناسبة كبيانات المريض على طاولة العمليات.

ولا تعيش المعلومات في الحاسوب وحده، فهي في الورق المطبوع وفي الأحاديث الجانبية وفي ذاكرة الموظفين وفي الرسائل النصية وفي الصور الملتقطة بالهاتف، ولهذا يتحدث المختصون عن حالات المعلومات

1

الثلاث، أي المعلومات أثناء التخزين (At Rest) على الأقراص والنسخ الاحتياطية، وأثناء النقل (In Transit) عبر الشبكات والبريد، وأثناء الاستخدام (In Use) في ذاكرة التطبيقات وعلى الشاشات، فالحماية التي تغطي حالة واحدة وتهمل الآخرين تشبه باباً محصناً في بيت بلا جدران. وتتم المعلومات بدورة حياة تبدأ بالإنشاء ثم التخزين ثم الاستخدام والمشاركة ثم الأرشفة ثم الإتلاف، وتحتاج كل مرحلة من هذه المراحل إلى حماية تناسبها، فالمعلومة التي أُتلفت بطريقة غير صحيحة قد تعود إلى الظهور من قرص بيع في سوق المستعمل، والمعلومة التي سُلِّت إلى طرف ثالث خرجت من نطاق سيطرتك ما لم تُضبط مشاركتها بعقد وضوابط.

1.2 الخصائص الثلاث: السرية والسلامة والتوافر



شكل 1.1 ثلاث السرية والسلامة والتوافر

يتفق المختصون على أن حماية المعلومات تعني الحفاظ على ثلاث خصائص أساسية يُعرف مجموعها بثلاث السرية والسلامة والتوافر (CIA Triad)، وكل خاصية منها تجيب عن سؤال مختلف، فأولها السرية (Confidentiality) وهي ألا يُطلع على المعلومة إلا من يحق له، فتجيب عن سؤال من يحق له أن يراها، وثانيها السلامة (Integrity) وهي أن تبقى المعلومة صحيحة وكاملة لا تُغيّر ولا تُحذف إلا بصلاحية، فتجيب عن سؤال هل المعلومة صحيحة ولم تُغيّر دون إذن، وثالثها التوافر

1

(Availability) وهو أن تكون المعلومة والخدمة في متناول من يحق له حين يحتاج إليها، فيجيب عن سؤال هل المعلومة موجودة حين نحتاج إليها. وتُنتهك السرية حين يُطلع على المعلومة من لا يحق له ذلك، سواء أكان السبب مهاجماً سرق قاعدة بيانات العملاء أم موظفاً فضولياً فتح ملف زميله الطبي أم جهازاً ضاع في سيارة أجرة وفيه نسخة غير مشفرة من العقود، وتشمل أدوات حفظ السرية التشفير الذي يحوّل المعلومة إلى صورة لا تُقرأ إلا بمفتاح، وضبط الصلاحيات وتصنيف المعلومات والتدريب على عدم إفشائها.

وتُنتهك السلامة حين تُغيّر المعلومة أو تُحذف أو تُختلق دون صلاحية، كأن يعدّل موظف رصيذاً في النظام أو يغيّر مهاجم رقم الحساب في فاتورة مرسلّة بالبريد لتذهب الحوالة إلى حسابه هو، وقد تُنتهك السلامة دون نية خبيثة نكطاً في البرمجة يفسد السجلات أو عطل في القرص، وتشمل أدوات حفظ السلامة دوال التجزئة (Hash Functions) التي تحوّل أي بيانات إلى بصمة قصيرة ثابتة الطول تتغير كلها إذا تغير حرف واحد في الأصل ولا يُستعاد الأصل منها، والتوقيع الرقمي الذي يثبت مصدر المعلومة وأنها لم تُمس بعد توقيعها، وسجلات التدقيق التي تدوّن من فعل ماذا ومتى، والفصل بين المهام، وضوابط التحقق من المدخلات التي تفحص ما يدخله المستخدم قبل قبوله.

ويُنتهك التوافر حين تصبح المعلومة أو الخدمة غير متاحة في الوقت الذي يحتاج إليها فيه أصحابها، كهجوم حجب الخدمة الذي يغرق بوابة حكومية بطلبات زائفة تفوق طاقتها فتتوقف في موسم تقديم الطلبات، أو برمجية فدية تغلق نظام مستشفى، أو انقطاع الكهرباء في ذروة الصيف عن مركز بيانات بلا مولد احتياطي، وتشمل أدوات حفظ التوافر التكرار (Redundancy) أي تجهيز نسخة ثانية من المكوّن الواحد نكادم أو

خط اتصال تحل محله عند تعطله، والنسخ الاحتياطي وخطط الاستمرارية والحماية من حجب الخدمة.

ولا يعني الثالث أن الخصائص الثلاث متساوية الأهمية في كل سياق، فالسرية هي الأولوية القصوى في بيانات الاستخبارات، بينما يتقدم التوافر في أنظمة التحكم الصناعي التي يعني توقفها خطراً على الأرواح، وتتقدم السلامة في الأنظمة المالية التي يهدد التلاعب بها الثقة كلها، ولهذا تبدأ أي حماية جادة بسؤال بسيط عن الخاصية التي يضر فقدانها أكثر من غيرها في هذا النظام تحديداً.

وقد أضاف المختصون إلى الثالث خصائص مكملة يرد ذكرها كثيراً في المعايير والعقود، وهي الأصالة (Authenticity) أي التأكد من أن المعلومة صادرة عن يدعي إصدارها، وعدم الإنكار (Non-repudiation) أي أن يعجز من قام بفعل في النظام عن إنكاره لاحقاً لوجود دليل يثبت عليه، كعميل وقّع عقداً إلكترونياً أو أرسل أمر تحويل ثم زعم أنه لم يفعل، ويُحَقَّق ذلك عادة بالتوقيع الرقمي، والمساءلة (Accountability) أي إمكانية نسبة كل فعل في النظام إلى شخص محدد، والخصوصية (Privacy) أي حق الأفراد في التحكم في معلوماتهم الشخصية، وهو ما أصبح له في دول الخليج أنظمة وقوانين خاصة سنفصلها في فصل أمن البيانات.

جدول 1.1 الخصائص الثلاث وما يحفظها

الخاصية	السؤال الذي تجيب عنه	مثال على انتهاكها	ضوابط نموذجية
السرية	من يحق له الاطلاع	تسريب قاعدة بيانات العملاء	التشفير وضبط الصلاحيات والتصنيف
السلامة	هل المعلومة صحيحة وغير معدلة	تغيير رقم حساب في فاتورة	دوال التجزئة والتوقيع الرقمي وسجلات التدقيق
التوافر	هل المعلومة متاحة وقت الحاجة	تعطل بوابة خدمات في موسم الذروة	التكرار والنسخ الاحتياطي وخطط الاستمرارية

1.3 أمن المعلومات والأمن السيبراني وحماية البيانات

تداخل هذه المصطلحات الثلاثة في الاستخدام اليومي حتى يظنها كثيرون شيئاً واحداً، غير أن لكل منها نطاقاً مختلفاً، فأمن المعلومات (Information Security) هو المظلة الأوسع لأنه يُعنى بحماية المعلومات سواء أكانت رقمية أم ورقية أم شفوية، أما الأمن السيبراني (Cybersecurity) فيركز على حماية الأنظمة الرقمية والشبكات والبيانات التي تمر عبرها من الهجمات الإلكترونية، فهو جزء من أمن المعلومات وإن كان الجزء الأكبر والأكثر حضوراً في عصرنا، وأما حماية البيانات (Data Protection) فتتطرق إلى المسألة من زاوية الحقوق والقانون، أي

حق الفرد في أن تُجمع بياناته الشخصية وتُعالج وتُحفظ وفق قواعد واضحة تحترم خصوصيته.

ويساعد التمييز بين النطاقات الثلاثة على تحديد المسؤوليات داخل المؤسسة، فحماية الوثيقة الورقية في الأرشيف من الحريق والسرقة مسؤولية أمن المعلومات ولا علاقة لها بالشبكة، وصدد هجوم على الموقع الإلكتروني عمل سيبراني بحت، وسؤال هل يحق لنا الاحتفاظ ببيانات هذا العميل بعد انتهاء تعامله معنا شأن من شؤون حماية البيانات يجيب عنه القانون والسياسة قبل التقنية، وفي الممارسة العملية تلتقي النطاقات الثلاثة في برنامج واحد يقوده الرئيس التنفيذي لأمن المعلومات (CISO) بالتعاون مع مسؤول حماية البيانات والمختصين القانونيين.

1.4 المفردات الأربع: الأصل والتهديد والثغرة والخطر

يتحدث المختصون بلغة تقوم على أربعة مصطلحات لا بد من إتقانها قبل أي شيء آخر، أولها الأصل (Asset) وهو كل ما له قيمة للمؤسسة ويحتاج إلى حماية، وقد يكون معلومة كقاعدة بيانات أو نظاماً نكادماً أو خدمة كالبوابة الإلكترونية أو إنساناً كموظف يحمل معرفة لا يملكها غيره أو سمعة يصعب استعادتها، وثانيها التهديد (Threat) وهو أي حدث أو فاعل يمكن أن يلحق الضرر بالأصل سواء أكان مهاجماً أم موظفاً مهملاً أم حريقاً أم عطلاً، وثالثها الثغرة (Vulnerability) وهي نقطة الضعف في الأصل أو في حمايته التي تتيح للتهديد أن يحقق ضرره، كبرمجية لم تُحدَّث أو كلمة مرور ضعيفة أو منفذ (Port) مفتوح على خادم بلا حاجة، والمنفذ هو الباب الرقي الذي تستقبل منه الخدمة اتصالاتها، ورابعها الخطر (Risk) وهو احتمال أن يستغل تهديداً ثغرةً في أصل مضرراً في حجم الأثر الناتج عن ذلك.

1

ويمكن تلخيص العلاقة بينها في معادلة بسيطة تقول إن الخطر هو حاصل اجتماع التهديد والثغرة والأثر، فإذا غاب أحد الثلاثة غاب الخطر، فالثغرة في نظام لا يهدده أحد ليست خطراً حقيقياً، والتهديد الذي لا يجد ثغرة يستغلها يبقى تهديداً نظرياً، والاستغلال الذي لا يترتب عليه أثر لا يستحق الموارد، وعلى هذه المعادلة يقوم علم إدارة المخاطر كله الذي نفصله في الفصل الثالث.

ويرتبط بهذه المفردات مصطلح الضابط (Control) وهو الإجراء الذي نتخذه لتقليل الخطر إما بإزالة الثغرة وإما بالحد من التهديد وإما بتخفيف الأثر، كالتشفير أو سياسة كلمات المرور أو قفل غرفة الخوادم، ومصطلح الخطر المتبقي (Residual Risk) وهو ما يبقى من الخطر بعد تطبيق الضوابط، في مقابل الخطر الكامن (Inherent Risk) الذي يُقدر قبل أي ضابط، فالبنك الذي يطلب من عملائه دليلاً ثانياً على هويتهم غير كلمة المرور يخفض خطر سرقة الحسابات كثيراً لكنه لا يلغيه، لأن الخطر لا ينعدم أبداً مهما أنفقنا، وإنما نخفضه إلى مستوى تقبله المؤسسة وهي واعية بما تقبله.

1.5 مبادئ لا تتغير

تتغير التقنيات كل بضع سنوات لكن مبادئ الحماية ثابتة منذ عقود، وأول هذه المبادئ الدفاع في العمق (Defense in Depth)، وتسميه الهيئة الوطنية للأمن السيبراني في السعودية الدفاع الأمني متعدد المراحل، وهو ألا ناعتمد على طبقة حماية واحدة مهما كانت قوية، بل نبني طبقات متتابعة بحيث إذا سقطت واحدة صدت التي بعدها، فالقلعة لها خندق وسور وأبراج وحرس لا سور واحد فقط، وكذلك الخادم يحجبه جدار حماية (Firewall) على حدود الشبكة يمرر الاتصالات المصرح بها ويمنع ما عداها، ثم ضبط الصلاحيات والتحديثات على الخادم نفسه، ثم تشفير

بياناته، ثم مراقبة تكشف ما تجاوز ذلك كله، وثانيها مبدأ الحد الأدنى من الصلاحيات (Least Privilege) الذي يقضي ألا يُمنح أي شخص أو نظام من الصلاحيات إلا ما يحتاج إليه لأداء عمله لا أكثر، فموظف خدمة العملاء يرى بيانات العميل الذي يخدمه ولا يملك تعديل رصيده، لأن كل صلاحية زائدة هي باب إضافي للمهاجم حين يستولي على الحساب الذي يحملها.

وثالثها الفصل بين المهام (Segregation of Duties) الذي يمنع أن يكون الشخص الواحد قادراً على إتمام عملية حساسة من بدايتها إلى نهايتها وحده، فمن يُدخل أمر الدفع لا يعتمد عليه، ومن يكتب البرنامج لا ينشره في بيئة الإنتاج التي يعمل عليها المستخدمون فعلاً، ورابعها افتراض الاختراق (Assume Breach) الذي يقضي بأن نصمم أنظمتنا على أساس أن المهاجم موجود في الداخل، فنراقب الشبكة ونجزئها إلى مناطق معزولة ونُحد من حركة من يدخلها بدل أن نطمئن إلى أن السور لم يُخترق بعد، ومن هذا المبدأ نشأ نموذج انعدام الثقة (Zero Trust) الذي لا يثق بطلب وصول لمجرد صدوره من داخل الشبكة بل يتحقق من صاحبه وجهازه عند كل طلب، ونفصله في فصل الهوية.

وخامسها البساطة، لأن النظام المعقد يصعب فهمه وتأمينه ومراجعته، وكل تعقيد زائد يخفي ثغرة محتملة، فجدار حماية تراكت فيه قواعد لا يذكر أحد سبب نصفها أخطر من جدار قواعده قليلة ومفهومة، وسادسها الأمن بالتصميم وبالإعداد الافتراضي (Secure by Design and by Default)، أي أن تُبنى الحماية في المنتج منذ لحظة تصميمه وأن تكون إعداداته الأولية آمنة دون أن يحتاج المستخدم إلى ضبطها، لأن الحماية التي تُضاف في النهاية تكون أضعف وأغلى، وسابعها أن الإنسان جزء من

النظام، فأقوى تشفير في العالم لا يحمي كلمة مرور كتبها صاحبها على ورقة ملصقة بالشاشة، ولذلك خصصنا لهذا الجانب فصلاً كاملاً.

1.6 أنواع الضوابط

تُصنف الضوابط من زاويتين، فمن زاوية طبيعتها تنقسم إلى ضوابط إدارية (Administrative) كالسياسات والإجراءات والتدريب والعقود، وضوابط تقنية (Technical) كجدران الحماية والتشفير وأنظمة كشف التسلل (Intrusion Detection Systems) التي تراقب حركة الشبكة وتنبّه إلى ما يشبه الهجوم، وضوابط مادية (Physical) كالأبواب والكاميرات والحراسة والأقفال، ولا تكتمل حماية بغير الأنواع الثلاثة لأن جدار الحماية لا يمنع موظفاً من إدخال غريب إلى غرفة الخوادم، والسياسة المكتوبة لا تمنع هجوماً آلياً على الشبكة.

ومن زاوية وظيفتها تنقسم الضوابط إلى خمس وظائف، فالضابط الوقائي (Preventive) يمنع الحدث قبل وقوعه كالمصادقة متعددة العوامل، والمصادقة (Authentication) هي التحقق من هوية المستخدم قبل السماح له بالدخول، وتصير متعددة العوامل حين تطلب مع كلمة المرور دليلاً ثانياً كرمز يصل إلى الهاتف أو بصمة الإصبع، والضابط الكاشف (Detective) يكتشف الحدث حين يقع أو بعده كأنظمة المراقبة وسجلات التدقيق، والضابط التصحيحي (Corrective) يعالج أثر الحدث كاستعادة النسخ الاحتياطية، والضابط الرادع (Deterrent) يثني المهاجم عن المحاولة كلافات التحذير والعقوبات المعلنة، والضابط التعويضي (Compensating) يحل محل ضابط أساسي تعذر تطبيقه كمراقبة مشددة لنظام قديم لا يمكن تحديثه.

جدول 1.2 وظائف الضوابط الخمس

الوظيفة	ماذا تفعل	أمثلة
وقائي	يمنع الحدث قبل وقوعه	المصادقة متعددة العوامل والتشفير
كاشف	يكشف الحدث عند وقوعه	أنظمة كشف التسلل وسجلات التدقيق
تصحيحي	يعالج أثر الحدث	استعادة النسخ الاحتياطية
رادع	يثني عن المحاولة	التحذيرات والعقوبات المعلنة
تعويضي	يحل محل ضابط متعذر	مراقبة مشددة لنظام قديم

1.7 لماذا تُخترق المؤسسات مع كل هذا

تكشف تحقيقات الحوادث عاماً بعد عام أن معظم الاختراقات لا تقع بسبب تقنيات هجوم متقدمة بل بسبب أخطاء معروفة، فثغرة لم تُسد مع أن تحديثها الأمني متاح منذ شهور، وحساب يحمل صلاحيات مدير بكلمة مرور تُستخدم في موقع آخر تسربت منه، وخدمة سحابية تُركت مفتوحة للجميع بإعداد خاطئ، وموظف ضغط على رابط في رسالة بدت كأنها من مديره، ومورد خارجي يملك صلاحية الوصول إلى الشبكة دون أن يعرف أحد ما يفعله بها، وغياب شبه كامل للمراقبة بحيث يبقى المهاجم في الشبكة أسابيع قبل أن يلاحظه أحد.

1

والقاسم المشترك بين هذه الأسباب أنها ليست مشكلات تقنية صرفة بل مشكلات في الإدارة والثقافة والانضباط، فالمؤسسة التي تعرف أصولها وتصنفها وتحديث أنظمتها وتضبط صلاحياتها وتراقب شبكتها وتدريب موظفيها تصد الغالبية العظمى من الهجمات بأدوات متاحة للجميع، أما المؤسسة التي تشتري أعلى المنتجات دون هذه الأساسيات فهي تضع قفلاً ذهبياً على باب مفتوح.

1.8 الأمن عملية مستمرة لا منتج يُشترى

نختم هذا الفصل بالفكرة التي تحكم الكتاب كله، وهي أن أمن المعلومات ليس حالة تصل إليها المؤسسة ثم تستريح، بل عملية دائرة لا تتوقف لأن الأصول تتغير والتهديدات تتطور والثغرات تُكتشف كل يوم، ويلخص إطار الأمن السيبراني الصادر عن المعهد الوطني الأمريكي للمعايير والتقنية (NIST CSF) هذه العملية في وظائف متتابعة تبدأ بالحوكمة ثم تحديد الأصول والمخاطر ثم الحماية ثم الكشف ثم الاستجابة ثم التعافي، وتعود الدائرة إلى بدايتها بما تعلمته المؤسسة من كل جولة، وعلى هذا الترتيب تقريباً بُنيت أبواب الكتاب.

! أخطاء شائعة

- شراء المنتجات قبل جرد الأصول وتصنيفها، فتُحمى أشياء لا تهم ويُترك الأهم
- الخلط بين الأمن السيبراني وأمن المعلومات فُهمل الوثائق الورقية والأحاديث والعنصر البشري
- الاعتماد على ضابط وقائي واحد كجدار الحماية دون كشف ولا تصحيح
- السعي إلى إزالة الخطر كله بدل خفضه إلى مستوى مقبول وموثق

- ترك قرار قبول الخطر لمدير تقنية المعلومات بدل مالك العملية الذي يتحمل الخسارة إن وقع

✓ قائمة تحقق

- ☐ قائمة أصول محدّثة بمالك لكل أصل
- ☐ تصنيف للمعلومات من ثلاثة إلى أربعة مستويات مطبق فعلاً
- ☐ لكل أصل حرج ضوابط وقائية وكاشفة وتصحيحية
- ☐ الخصائص الثلاث محددة الأولوية لكل نظام حرج
- ☐ مبدأ الحد الأدنى من الصلاحيات مطبق على الحسابات ذات الصلاحيات الحساسة على الأقل
- ☐ الفصل بين المهام في العمليات المالية والنشر
- ☐ سجل بالمخاطر المتبقية المقبولة وموقع ممن قبلها
- ☐ دورة مراجعة منتظمة للضوابط لا مشروع ينتهي

☰ خلاصة الفصل

- المعلومات أصل له قيمة وتوجد في ثلاث حالات هي التخزين والنقل والاستخدام، وتتم بدورة حياة من الإنشاء إلى الإتلاف
- نحجي ثلاث خصائص هي السرية والسلامة والتوافر، وتضاف إليها الأصالة وعدم الإنكار والمساءلة والخصوصية
- أمن المعلومات مظلة أوسع من الأمن السيبراني، بينما تنظر حماية البيانات من زاوية الحقوق والقانون
- الخطر هو اجتماع تهديد وثغرة في أصل مع أثر، والضوابط تخفضه إلى خطر متبقي مقبول
- المبادئ الثابتة سبعة هي الدفاع في العمق والحد الأدنى من الصلاحيات والفصل بين المهام وافترض الاختراق والبساطة

والأمن بالتصميم وبالإعداد الافتراضي، وأن الإنسان جزء من النظام

- الضوابط إدارية وتقنية ومادية بطبيعتها، ووقائية وكاشفة وتصحيحية ورادعة وتعويضية بوظيفتها

المصطلحات الأساسية

المصطلح	بالإنجليزية	المعنى
السرية	Confidentiality	ألا يطلع على المعلومة إلا من يحق له ذلك
السلامة	Integrity	بقاء المعلومة صحيحة وكاملة لا تُغيّر ولا تُحذف إلا بصلاحية
التوافر	Availability	أن تكون المعلومة والخدمة في متناول أصحابها حين يحتاجون إليها
عدم الإنكار	Non-repudiation	عجز من قام بفعل في النظام عن إنكاره لوجود دليل يثبتته
الأصل	Asset	كل ما له قيمة للمؤسسة ويحتاج إلى حماية من معلومات وأنظمة وأشخاص
التهديد	Threat	أي حدث أو فاعل يمكن أن يلحق الضرر بالأصل
الثغرة	Vulnerability	نقطة ضعف في الأصل أو في حمايته تتيح للتهديد أن يحقق ضرره

المصطلح	بالإنجليزية	المعنى
الخطر	Risk	احتمال أن يستغل تهديد ثغرة في أصل مضروباً في حجم الأثر
الضابط	Control	إجراء يخفف الخطر بإزالة الثغرة أو الحد من التهديد أو تخفيف الأثر
الخطر المتبقي	Residual Risk	ما يبقى من الخطر بعد تطبيق الضوابط
الدفاع في العمق	Defense in Depth	بناء طبقات حماية متتابعة تصد كل منها ما تجاوز التي قبلها
مبدأ الحد الأدنى من الصلاحيات	Least Privilege	ألا يُمنح الشخص أو النظام إلا الصلاحيات التي يحتاج إليها لعمله
الفصل بين المهام	Segregation of Duties	ألا يستطيع شخص واحد إتمام عملية حساسة من بدايتها إلى نهايتها وحده

٨ خريطة إلى الأطر

يؤسس هذا الفصل للمفاهيم التي تقوم عليها كل الأطر، فالخصائص الثلاث هي تعريف أمن المعلومات في المعيار الدولي ISO/IEC 27000، ودورة الوظائف من الحوكمة إلى التعافي هي بنية إطار NIST CSF في إصداره الثاني، ومفردات الأصل والتهديد والثغرة والخطر هي لغة فصول إدارة المخاطر في الأطر الخليجية كلها.

أسئلة للمراجعة ؟

- 1 ما الفرق بين البيانات والمعلومات والمعرفة، وأيها نحجي؟
- 2 أي نظام تتقدم فيه السلامة على السرية، ولماذا اخترته؟
- 3 لماذا لا يكفي ضابط وقائي واحد مهما كانت قوته؟
- 4 ما الخطر المتبقي ومن يقرر قبوله؟
- 5 كيف تصنف الضوابط الآتية بحسب طبيعتها ووظيفتها: كاميرا المراقبة، وسياسة كلمات المرور، ونظام النسخ الاحتياطي، وتشفير القرص؟
- 6 لماذا يوصف أمن المعلومات بأنه عملية لا منتج؟

تمارين تطبيقية

تمرين 1.1

اختر نظاماً تتعامل معه يومياً كتطبيق البنك أو بوابة الجامعة، وحدد لكل خاصية من الخصائص الثلاث مثلاً على انتهاكها وأثر ذلك فيك

تمرين 1.2

أعد قائمة بعشرة أصول في مؤسسة صغيرة تخيلها وصنف كل أصل بحسب الخاصية التي يضر فقدانها أكثر

تمرين 1.3

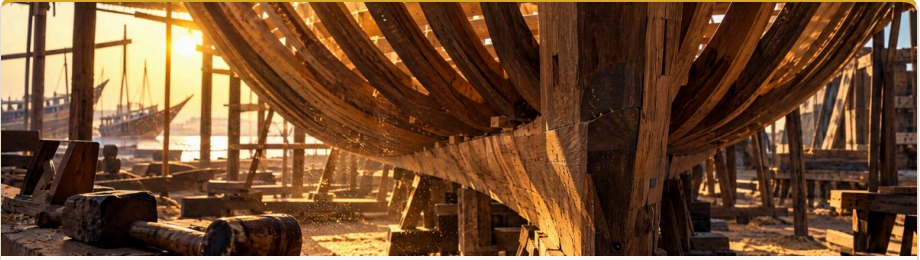
صنف خمسة عشر ضابطاً تعرفها في جدول من بعدين هما الطبيعة والوظيفة
ولاحظ الخانات الفارغة

للتعمق ومصادر الفصل

- ♦ المعيار الدولي ISO/IEC 27000 للمصطلحات والمفاهيم الأساسية
- ♦ إطار NIST CSF في إصداره الثاني ووثيقته التعريفية
- ♦ الضوابط الحرجة CIS Controls في إصدارها الثامن ودليل مجموعات التطبيق
- ♦ المسرد الرسمي للأمن السيبراني الصادر عن الهيئة الوطنية للأمن السيبراني في السعودية

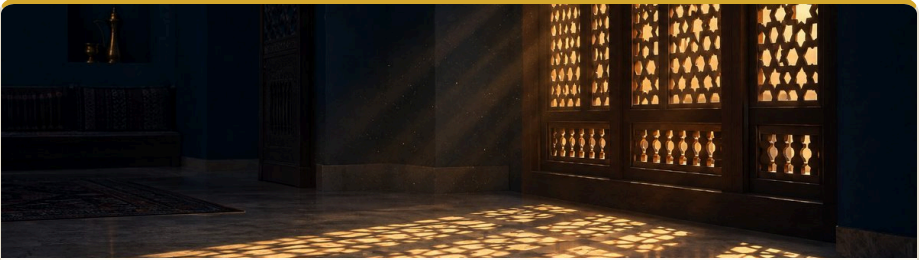
ماذا ينتظرك في الكتاب

ثمانية عشر فصلاً آخر في أربعة أبواب نترج من الأسس إلى الآفاق.



١ الباب الأول: الأسس

- | | |
|---|--------------------------------------|
| 1 مدخل إلى أمن المعلومات قرأته | 3 إدارة المخاطر |
| 2 التهديدات والمهاجمون | 4 الحوكمة والسياسات والأطر والامتثال |



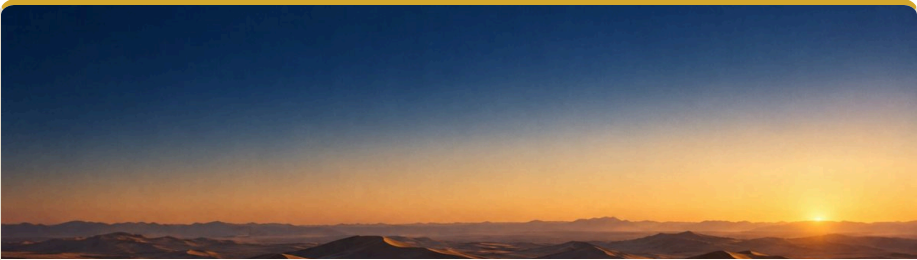
٢ الباب الثاني: الضوابط التقنية

- | | |
|-------------------------------------|---|
| 5 التشفير | 10 أمن الحوسبة السحابية |
| 6 الهوية والمصادقة وإدارة الصلاحيات | 11 أمن البيانات والخصوصية |
| 7 أمن الشبكات | 12 أمن الأنظمة الصناعية وإنترنت الأشياء |
| 8 أمن الأنظمة ونقاط النهاية | 13 المعمارية الأمنية |
| 9 أمن التطبيقات والتطوير الآمن | |



الباب الثالث: العمليات والصمود ٣

- | | |
|----|---------------------------------------|
| 14 | مراقبة الأمن والعمليات الأمنية |
| 15 | الاستجابة للحوادث والتحقيق الرقمي |
| 16 | استمرارية الأعمال والتعافي من الكوارث |
| 17 | العنصر البشري والتوعية الأمنية |



الباب الرابع: آفاق ٤

- | | |
|----|----------------------------------|
| 18 | الذكاء الاصطناعي وأمن المعلومات |
| 19 | المسيرة المهنية في أمن المعلومات |

وفي الملاحق قائمة تحقق من أربعين ضابطاً للمؤسسة الصغيرة والمتوسطة، ومسرد يضم أكثر من مئتي مصطلح بالعربية والإنجليزية، والمراجع الدولية والمحلية.

- في كل فصل** أهداف التعلم أشكال ودراسات حالة أخطاء شائعة وقائمة تحقق خلاصة ومصطلحات خريطة إلى الأطر أسئلة وتمارين مصادر للتعمق



أكمل القراءة

المرجع الخليجي الشامل في الأمن السيبراني

انتهى الفصل الأول، وبعده ثمانية عشر فصلاً في أربعة أبواب تُتدرج من الأسس إلى الآفاق، وفي الكتاب ثلاثة وعشرون شكلاً توضيحياً ومسردياً يضم أكثر من مئتي مصطلح وقائمة تحقق للمؤسسة الصغيرة والمتوسطة.

اشترِ الكتاب من أمازون

امسح الرمز لتفتح صفحة الكتاب
على أمازون من هاتفك

amazon.com/dp/B0H6R5RR39



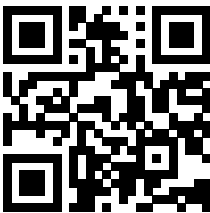
من الخليج إلى الخليج

كتاب عربي شامل في أمن المعلومات والأمن السيبراني كُتب من الخليج إلى الخليج، يجمع الأساس النظري والممارسة العملية والسياق التنظيمي لدول مجلس التعاون في مرجع واحد يصلح للمقرر الجامعي ولبرامج التأهيل الحكومية وللممارس في الميدان.

تسعة عشر فصلاً في أربعة أبواب تتدرج من الأسس إلى الآفاق، يبدأ كل فصل بأهداف تعلم ويُختم بأخطاء شائعة وقائمة تحقق وخلاصة وجدول مصطلحات وخريطة إلى الأطر الدولية والخليجية وأسئلة وتمارين ومصادر، مع ثلاثة وعشرين شكلاً ودراسات حالة من واقع المنطقة، وملاحق فيها قائمة تحقق للمؤسسة الصغيرة ومسرد يضم أكثر من مئتي مصطلح.

يضع الكتاب إطار بنك الكويت المركزي الجديد والضوابط الأساسية السعودية ومعياري ضمان المعلومات في قطر وقوانين حماية البيانات في الدول الست في موضعها من كل فصل، ويرافقه موقع فيه فصل مجاني ومستودع مفتوح بالتدريبات والقوالب والأشكال.

علي العنزي مهندس وقيادي في أمن المعلومات، يقود أعمال هندسة الأمن في إحدى كبرى المؤسسات المالية في الكويت، ويرأس لجاناً لمخاطر الأمن السيبراني في القطاع المالي في الكويت والخليج، وهو عضو مجلس إدارة سابق في إحدى شركات تكنولوجيا المعلومات في الكويت.



الفصل الأول مجاناً
والتدريبات والقوالب
gulfcyber.3li.info

ISBN 9798178685440



9 798178 685440